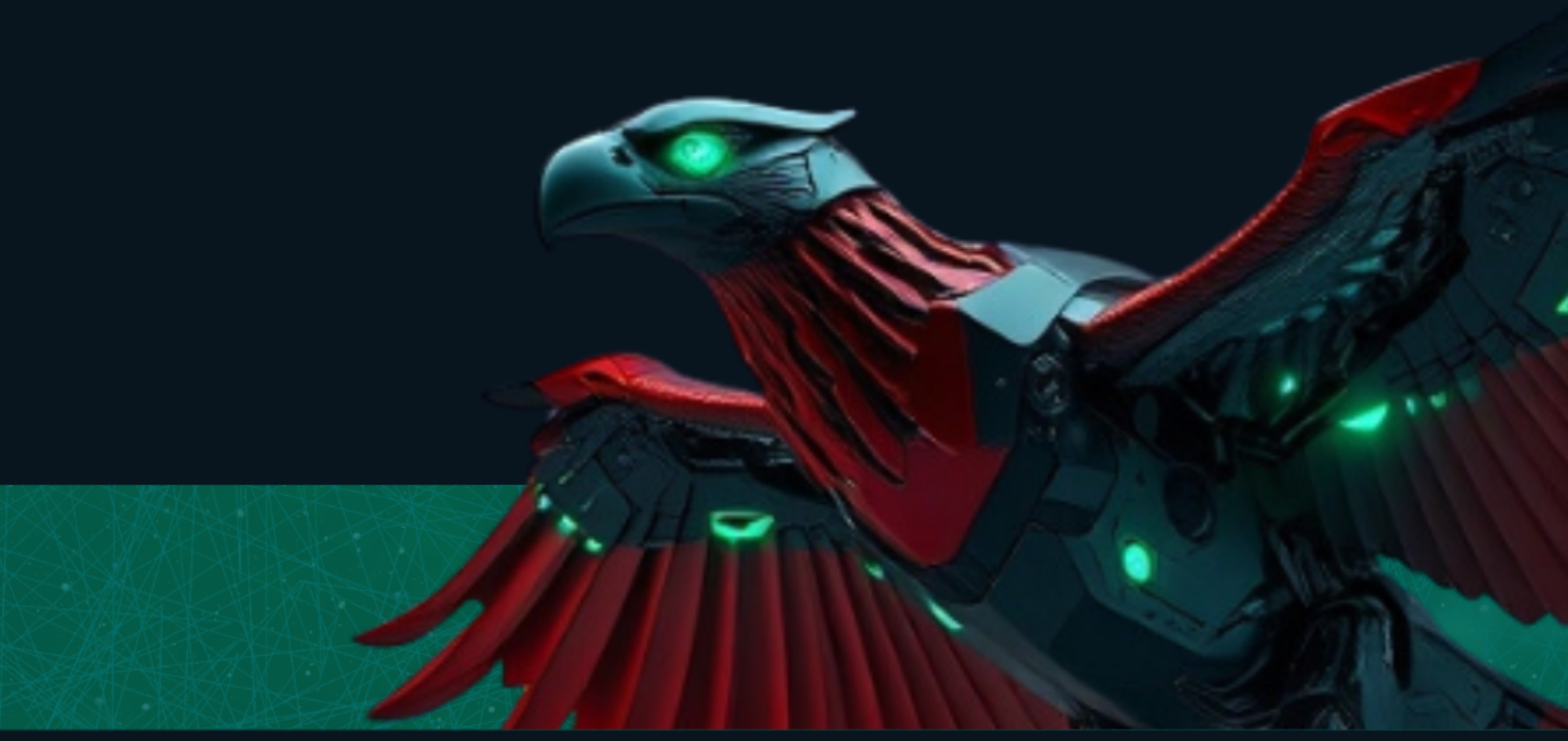
SOCBYTE
ALL BYTES SECURED

INTEL REPORT



Report Details

Title	CVE-2026-4427
Sub Title	Improper access control on API endpoints
Status	Closed
Type	Advisory
Severity	—
Source	Fortinet
Created At	May 18, 2026, 08:53 PM

CVE-2026-4427

Improper access control on API endpoints

Type: ADVISORY • Source: Fortinet • Created At: May 18, 2026, 08:53 PM

Analysis Summary

CVE-2026-44277 is a critical improper access control flaw in Fortinet FortiAuthenticator's API endpoints that lets an unauthenticated remote attacker run unauthorized code or commands on the device by sending crafted API requests. Due to the API not properly enforcing authentication and authorization checks on certain endpoints, a malicious actor on the network can talk directly to those APIs over HTTPS and have their requests treated as if they were a trusted, logged in admin. In practice, the attacker sends specially crafted requests to exposed FortiAuthenticator API endpoints, and the appliance processes them with far more privilege than it should, which can lead to full remote code execution on the FortiAuthenticator system. Once they control FortiAuthenticator, they can tamper with MFA and identity workflows, add or modify users, steal authentication data, or change policies that protect VPN and admin access, effectively turning a core identity system into a pivot point for broader compromise across the organization's network. Since FortiAuthenticator usually sits at the center of IAM, VPN, and privileged access, a successful exploit can undermine trust in the entire authentication stack and give attackers a path to move laterally, escalate privileges, and impact many connected services and infrastructure components.

Affected Product

- Fortinet- FortiAuthenticator
- affected at 8.0.2,
- affected at 8.0.0,
- affected from 6.6.0 through 6.6.8,
- affected from 6.5.0 through 6.5.6,
- affected from 6.4.0 through 6.4.10

Impact

- T1486: Data Encrypted for Impact
- T1499: Endpoint Denial of Service
- T1485: Data Destruction
- T1565: Data Manipulation
- T1490: Inhibit System Recovery

Vulnerabilities (CVEs)

CVE Number	Description	Published	CVSS Score
CVE-2026-44277	An Improper Access Control vulnerability [CWE-284] in FortiAuthenticator may allow an unauthenticated attacker to execute unauthorized code or commands via crafted requests.	5/11/2026	9.1

Remediation

- Upgrade FortiAuthenticator **8.0 to 8.0.3 or later.**
- Upgrade FortiAuthenticator **6.6 to 6.6.9 or later.**
- Upgrade FortiAuthenticator **6.5 to 6.5.7 or later**.
- As a workaround, disable API access on exposed interfaces under:

Network ’ Interfaces ’ Access Rights.

- Validate that FortiAuthenticator API exposure is not internet-facing unless explicitly required.